

CSIT302 Cybersecurity

Day 1-1 – Security Posture

Subject Coordinator: Dr Partha Sarathi Roy
School of Computing and Information Technology

About This Subject

- Lecturer:

- Dr Partha Sarathi Roy

- ✓ Lecturer at SCIT, UOW

- ✓ Email: partha@uow.edu.au

About This Subject

- Lectures

- Lecture notes and recorded lectures will be available from Moodle. (Warning: There could be last-minute changes before the actual lecture.)

- Workshop (Tutorial)

- Important to attend. There are quizzes in tutorial weeks 2, 4 and 7 (tentative).

- Textbook

- ✓ Y. Diogenes and E. Ozkaya, Cybersecurity – Attack and Defense Strategies, Packt Publishing, 2018, ISBN 978-78847-529-7

About This Subject

- Assessments

- 3 Quizzes

- ✓ Taken during tutorial classes on weeks 2, 4 and 7 (tentative)
 - ✓ Total 30% (10% per each)

- Assignment

- ✓ Assignment will be either written reports or programs (or combined).
 - ✓ Total 20%

- Final

- ✓ Technical failure: below 40 out of 100
 - ✓ Total 50%

What is Cybersecurity?

- Cybersecurity (Definition by E. Lewis)

- *A set of technologies, practices and processes that are created and designed to safeguard programs, network systems that connect computers, software and virtual data against any invasion or an attempt to damage.*
- Many definitions exist. (No definition is perfect.)
- Cybersecurity is a broad area of security that encompasses
 - ✓ Computer security
 - ✓ Network security
 - ✓ Software/hardware security and etc.

What is Cybersecurity?

- Cyberattacks

- The reason why we need cybersecurity.
- They are malicious activities happening in the cyberspace.
- Cybersecurity diminishes the risk of cyberattacks and protects individuals and organizations from any kind of unauthorized exploitation of data, network systems and technologies.

What is Cybersecurity?

- The investment in cybersecurity is *crucial* for successful businesses.
 - It moved from *nice-to-have* to *must-have*.
 - Failure in cybersecurity results in irrevocable damage or even bankruptcy.



Facebook–Cambridge Analytica data scandal was revealed.

What is Cybersecurity?

- British Airways faces record £183m (AUD 330m) fine for data (customers credit cards) breach.
 - Breach happened in June 2018 (and revealed in September 2018).
 - This is about 350 times higher than the fine imposed on Facebook (previous record high) over the Cambridge-Analytica scandal.
 - The first fine imposed to the company under the EU's new **GDPR (General Data Protection Regulation)** law.
- Also, many incident reported regarding to Cryptocurrency.
 - Multiple coin exchange companies were bankrupted due to (cyber-)security breaches.
 - ✓ MtGox - 70% of bitcoins were traded in MtGox before the breach. It lost 850,000 bitcoins and bankrupted (2014).
 - ✓ The South Korean exchange Yobit shut down and filed for bankruptcy after being hacked twice (2017).
 - ✓ Japan's Coincheck was hacked and more than USD 500m-worth of digital currency stolen (2018).

What is Cybersecurity

- Data breaches in Australia, e.g.,
 - In September 2022, Australian telecommunications giant Optus suffered data breach, affecting up to 10 million customers.
 - In December 2022, Medibank, the Australian health insurance giant, was the victim of a major data breach, affecting the personal details of 9.7 million customers.

The Medibank logo, featuring the word "medibank" in a bold, sans-serif font. The "i" is stylized with a blue dot and a blue vertical bar, while the rest of the letters are red.

Goals of Cybersecurity

- Secrecy
 - The effect of mechanisms used to limit the number of principals who can access information, such as cryptography and access control.
- Confidentiality
 - An obligation to protect some other person's or organisation's secrets if you know them.
- Privacy
 - Privacy is the ability and/or right to protect your personal information and extends to the ability and/or right to prevent invasions of your personal space.

Goals of Cybersecurity

- Caution

- The above definitions are from Ross Anderson, who is an eminent cybersecurity researcher.
- The terms can have different meaning in different discipline. For example, “confidentiality” is often used to refer to “secrecy” in cryptography.
- Typically, privacy is secrecy for the benefit of the individual while confidentiality is secrecy for the benefit of the organisation.

Security Posture

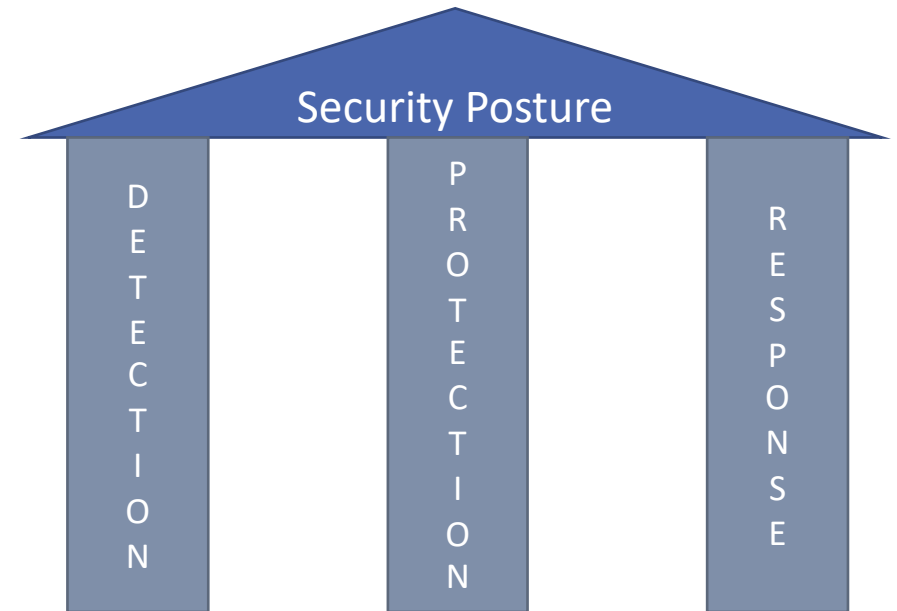


UNIVERSITY
OF WOLLONGONG
AUSTRALIA

This slide is copyrighted. It must not be distributed without permission from UOW

Security Posture

- *Achieving the goals of cybersecurity leads to **enhancing the security posture** of the organisation.*
- Solidifying **protection** system for organization's security is not enough.
- **Detection** and **response** must be aligned to enhance overall security posture.
 - Enhancing detection systems to quickly identify an attack.
 - Enhancing the effectiveness of the response process to reduce the time between infection and containment.



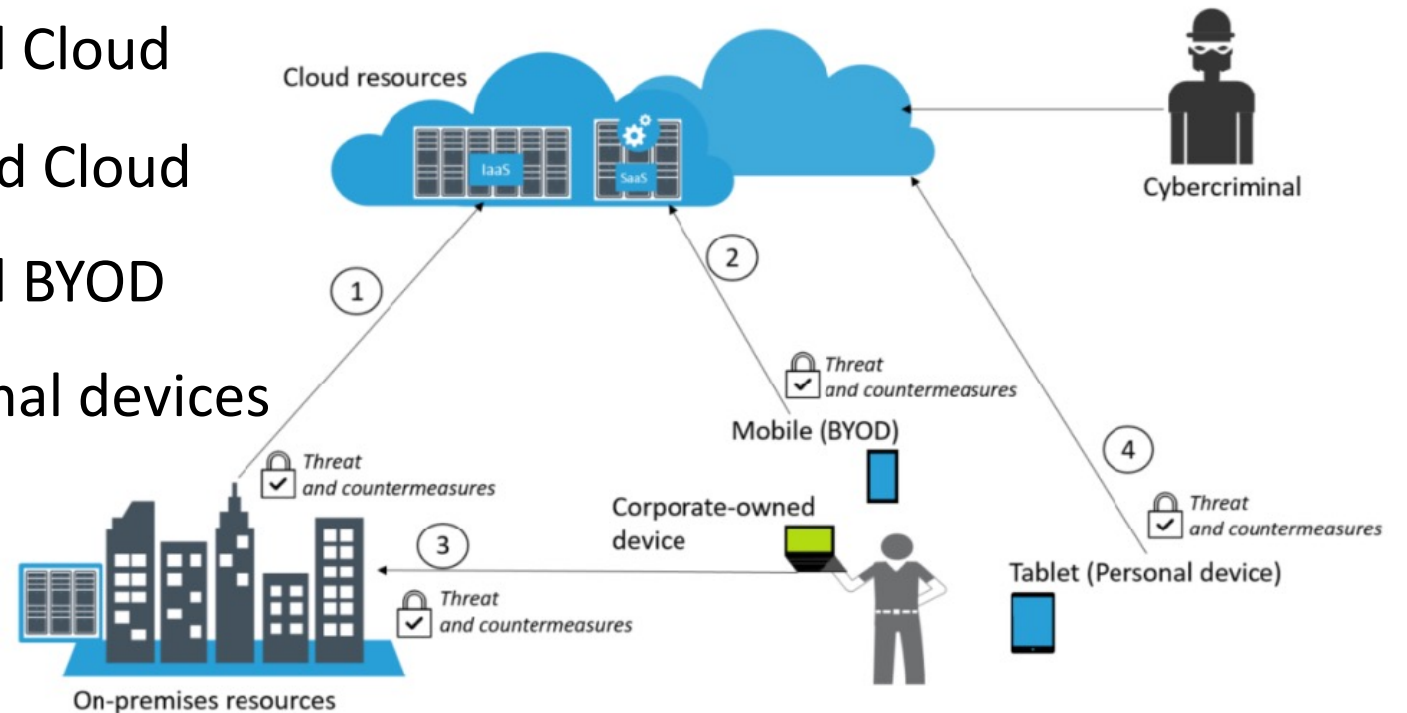
The Current Threat Landscape

- The threat landscape is continuously expanding as many organisations allow working flexibility such as remote access or **BYOD**:
- Remote Access
 - The number of remote workers is growing. (e.g., Forty-three percent of employed Americans already work remotely in 2016). It means they use their own infrastructure to access the company's resources.
 - COVID-19 forced a huge experiment in our ability to work remotely. By May 2020, in response to the COVID-19 pandemic, 46% of NSW workers were working from home.
- Bring Your Own Device (BYOD)
 - There is a growth in the number of companies allowing BYOD in the workplace.
 - Most of the failures in the BYOD scenario usually happen because of poor planning and network architecture, which lead to an insecure implementation.

The Current Threat Landscape

- For entry points for the end user based on connectivity to be consider:

- 1) Between On-premises and Cloud
- 2) Between BYOD devices and Cloud
- 3) Between On-premises and BYOD
- 4) Between Cloud and Personal devices



The Current Threat Landscape

- Many companies are adopting **cloud computing**:
 - **Infrastructure as a service (IaaS)** provides scalable and automated computing resources for accessing and monitoring computers, networking, storage and other services.
 - ✓ Ex) AWS Elastic Computing (EC2), Microsoft Azure, Google Compute Engine
 - **Platform as a service (PaaS)** provides developers with an entire environment for the development and deployment of apps in the cloud.
 - ✓ Ex) AWS Elastic Beanstalk, Microsoft Azure, Heroku
 - **Software as a service (SaaS)** is a software delivery model in which software is licensed on a subscription basis and is centrally hosted through cloud.
 - ✓ Ex) Microsoft Office365, Google Docs, Dropbox

The Current Threat Landscape

- Caution with IaaS

- When an organization decides to extend their on-premise infrastructure with a cloud provider to use IaaS, *the company needs to evaluate the threats for this connection and the countermeasure for these threats through a risk assessment.*
- A similar caution must be exercised for PaaS.

The Current Threat Landscape

- Caution with SaaS

- A personal device has no direct connectivity with on-premise resources. However, if this device is compromised, the user could potentially compromise the company's data in the following situations:

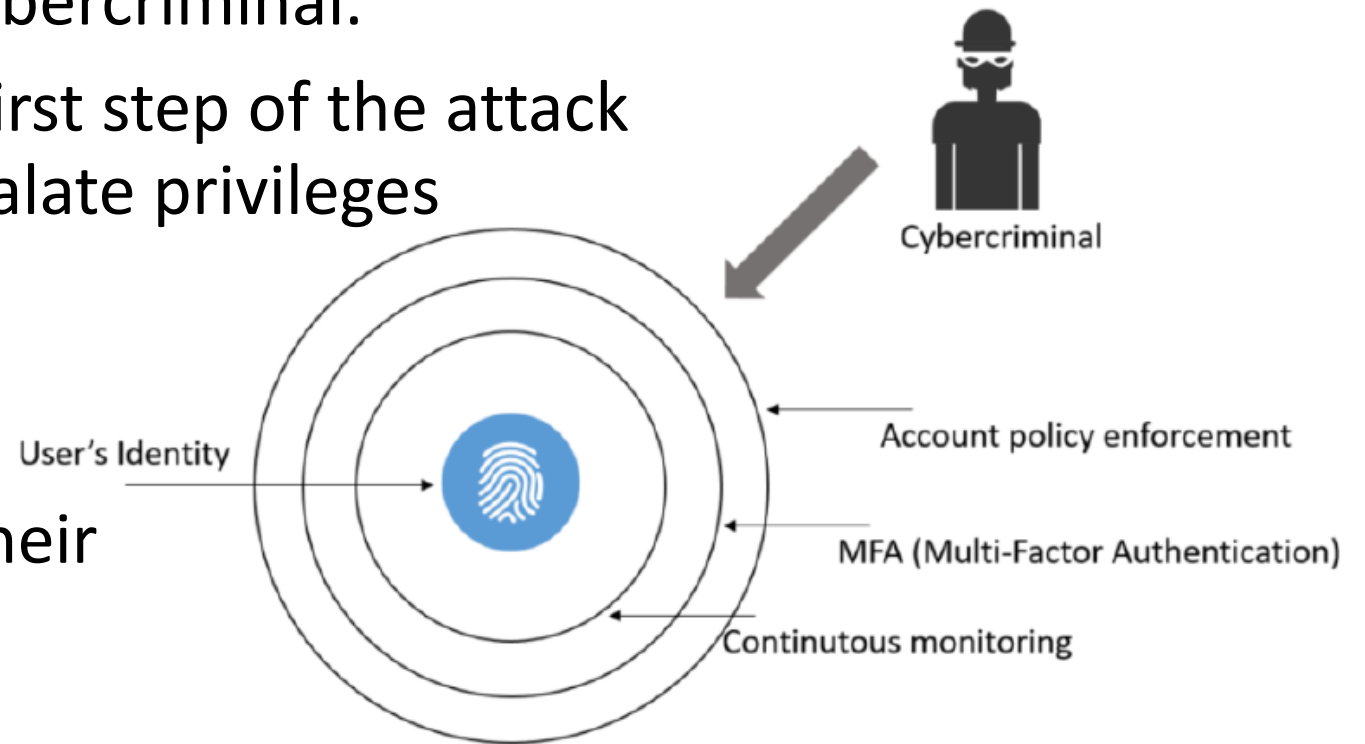
- ✓ Opening a corporate email from this device;
 - ✓ Accessing corporate SaaS applications from this device;
 - ✓ If the user uses the same password for his/her personal email and his corporate account, this could lead to account compromise through brute force or password guessing.

- Security awareness training:

- Having technical security controls is important to mitigate some of these threats against the end user, but the main protection is conducting **security awareness training**.

The Credential

- A user's identity is the new perimeter. Stealing credentials is the preferred attack vector of cybercriminal.
- Credential theft could be a first step of the attack to get an opportunity to escalate privileges to a domain administrator.
- Company must focus on *authentication* and *authorization* of users and their access rights.



The Credential

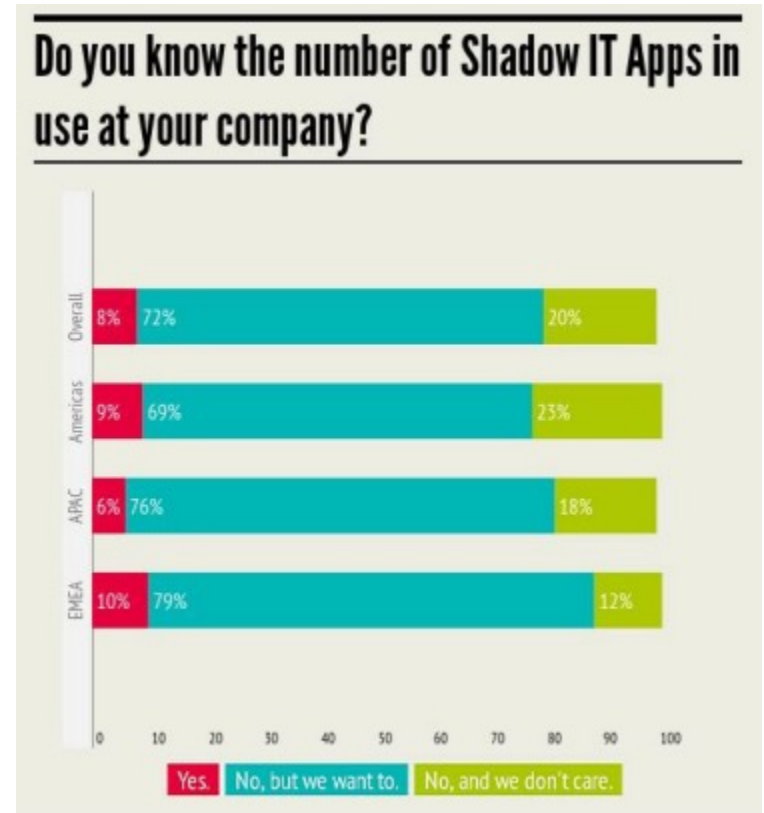
- **MFA (Multi Factor Authentication):**
 - Using multi factors for the authentication. For examples, Australian electronic government (my.gov.au) requires ID/Password + One-time password. One-time password is delivered through a registered mobile number after a user is authenticated by ID/Password.
 - Other factors which can be used for the authentication are biometric information such as finger prints, Irises, face recognitions and voices.
- **Continuous monitoring:**
 - *Continuous monitoring (continuous authentication)* is a new technology that uses a person's behaviour to continuously verify their identity throughout a session — not just at the entry login point.

Applications (Apps)

- Applications are the entry points for users to *consume data and transmit, process or store information onto the system.*
- Security consideration taken to those apps:
 - Apps developed in-house: Measures should be taken to ensure that the apps are using a secure framework throughout the software development lifecycle.
 - Apps that users are paying for as a service: The vendor's security and compliance policy should be checked carefully to verify whether your company's security and compliance requirements are met.

Applications (Apps)

- Personal apps on BYOD: Every user has their own sets of apps in their own device. Users are consuming many apps that may not be secure.
- **Shadow IT**: Systems developed by individual departments other than the central IT department. They don't give IT managers the visibility they need to know how employees are using them.
 - Sometimes it gives us efficiency but security breaches happen frequently. → “You can't protect something you don't know you have.”



CLOUD ADOPTION PRACTICES &
PRIORITIES SURVEY REPORT (CSA, Jan. 2015)

Examples of Threats and Countermeasures

- Examples of threats and countermeasures for the data:

State	Description	Threats	Countermeasures
Data at rest on the user's device	The data is located on the user's device.	Unauthorized or malicious process could read or modify the data	Data encryption: File level or disk encryption
Data in transit	The data is being transferred from one host to another.	A man-in-the-middle attack could read, modify, or hijack the data	SSL/TLS with valid certificates
Data at rest on-premise or cloud	The data is located at rest either on the server's hard drive located on-premise or in the cloud.	Unauthorized or malicious process could read or modify the data	Data encryption: File level or disk encryption

Cybersecurity Challenges

- The top causes for the costliest data breaches in an order:
 1. Malware (viruses and Trojans)
 2. Lack of diligence and untrained employees
 3. Phishing and social engineering
 4. Targeted attack
 5. Ransomware
 6. Government-sponsored attack

Cybersecurity Challenges

- *Top three (1, 2, 3)*

- The real problem with them is that they are usually correlated to *human error*. Everything may start with a phishing email that uses **social engineering** to lead the employee to click on a link that may download a virus, malware, or Trojan.
 - Human are considered as the weakest link in cybersecurity.

Cybersecurity Challenges

- *Targeted attack* (4)

- The attacker has a **specific target** in mind when he/she starts to create a plan of attack. During this initial phase, the attacker will spend a lot of time and resources to perform public *reconnaissance* to obtain the necessary information to carry out the attack.
- Another attribute for the targeted attack is the **longevity**, or the amount of time that they maintain persistent access to the target's network. The intent is to continue moving laterally across the network, compromising different systems until the goal is reached.

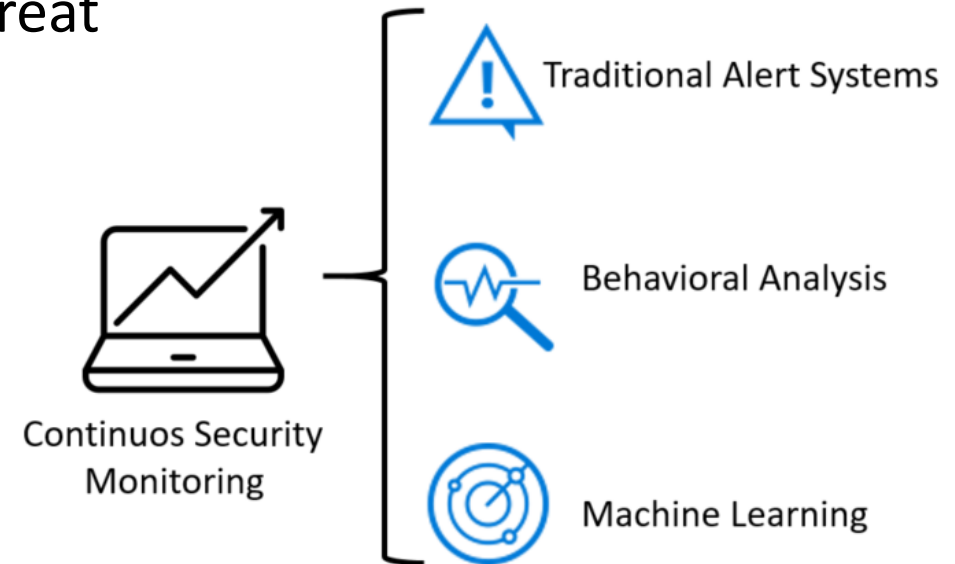
Cybersecurity Challenges

- *Ransomware (5)*

- In May 2017, the world was shocked by the biggest ransomware attack in history, called Wannacry.
- Wannacry infected more than 400,000 machines across the globe, which is a gigantic number, never seen before in this type of attack.
- This ransomware exploited a known Windows SMBv1 vulnerability (EternalBlue) that had a patch released in March 2017 (59 days prior to the attack). → It shows that companies across the world are still failing to implement an effective vulnerability management program.

Cybersecurity Challenges

- *Government-sponsored cyber attacks (data as a weapon) (6)*
 - The intent is to steal information that can be used against the hacked party.
 - The private sector should not ignore these signs.
 - Organizations start to invest more in threat intelligence, machine learning, and analytics to protect their assets.



The Red and Blue Team

- The original concept of **the Red and Blue Team** was introduced a long time ago during World War I. The general idea was to demonstrate the effectiveness of an attack through *simulations*.
- In the cybersecurity field, the adoption of the Red and Blue Team approach also helped organizations to keep their assets more secure.
- The **Red Team** will perform an *attack* and penetrate the environment by trying to breakthrough the current security controls, also known as penetration testing.
- The **Blue Team** needs to ensure that the assets are *secure* and in case the Red Team finds a vulnerability and exploits it, they need to rapidly remediate and document it as part of the lessons learned.

The Red Team

- The Red Team must be composed of highly trained individuals, with different skill sets and they must be fully aware of the current threat landscape for the organization's industry.
- The Red Team must be *aware of trends and understand how current attacks* are taking place.
- In some circumstances and depending on the organization's requirements, members of the Red Team *must have coding skills to create their own exploit and customize it* to better exploit relevant vulnerabilities that could affect the organization.

The Red Team

- The main metrics of the red team:
 - **Mean Time to Compromise (MTTC)**: This starts counting from the minute that the Red Team initiated the attack to the moment that they were able to successfully compromise the target
 - **Mean Time to Privilege Escalation (MTPE)**: This starts at the same point as the previous metric, but goes all the way to full compromise, which is the moment that the Red Team has administrative privilege on the target

The Blue Team

- The Blue Team members should also have a wide variety of skill sets and should be composed of professionals from different departments.
- The Blue Team also has accountability for some security metrics as follows:
 - **Estimated Time to Detection (ETTD)**
 - **Estimated Time to Recovery (ETTR)**
- Those metrics is not 100% precise.
 - The true reality is that the Blue Team might not know precisely what time the Red Team was able to compromise the system.

The Blue Team

- What does the Blue Team do when the Red Team is able to breach the system:
 - **Save evidence:** It is imperative to save evidence during these incidents to ensure you have *tangible information to analyze, rationalize, and take action* to mitigate in the future.
 - **Validate the evidence:** Not every single alert, or in this case evidence, will lead you to a valid attempt to breach the system. But if it does, it needs to be catalogued as an **Indication of Compromise (IoC)**.
 - **Engage whoever is necessary to engage:** At this point, the Blue Team must know what to do with this IoC, and which team should be aware of this compromise. *Engage all relevant teams*, which may vary according to the organization.

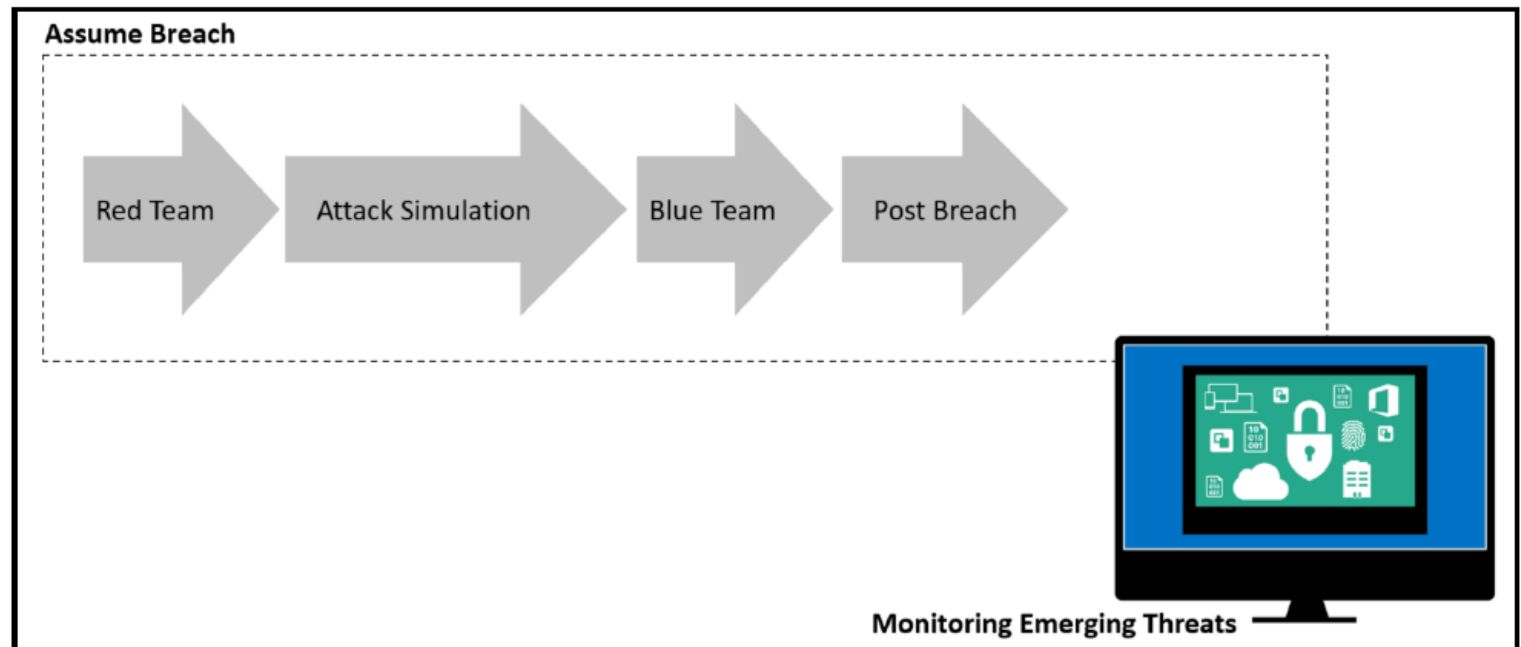
The Blue Team

- What does the Blue Team do when the Red Team is able to breach the system:
 - **Triage the incident:** Sometimes the Blue Team may need to *engage law enforcement*, or they may need *a warrant* in order to perform the further investigation, a proper triage will help on this process.
 - **Scope the breach:** At this point, the Blue Team has enough information to scope the breach.
 - **Create a remediation plan:** The Blue Team should put together a remediation plan *to either isolate or evict the adversary*.
 - **Execute the plan:** Once the plan is finished, the Blue Team needs to execute it and recover from the breach.

Assuming Breach

"Fundamentally, if somebody wants to get in, they're getting in. Alright, good. Accept that."

- Michael Hayden (the former director of the CIA and NSA)



Assuming Breach

- Due to the emerging threats and cyber security challenges, it was necessary to change the methodology from *preventing breach* to ***assuming breach***.
- The traditional "prevent breach" approach by itself does not promote the ongoing testing. → You must always be refining your protection to deal with modern threats.
- The red and blue team simulation should not be a one-off exercise, instead, must be a *continuous process* that will be refined and improved with best practices over time.